

Cirque Corporation

Supplier Security Review Procedure

Document ID: IS-CIRQ-PR-019-G

Category: Related to Outsourcing

Division: Procedure

Type: Global

Version: 1.0

Effective Date: 2025-07-01

Review Date: 2026-07-01

Approved By: IT Manager

Generated: March 02, 2026

1. Purpose

The purpose of this procedure is to define the systematic process for conducting information security reviews of existing and prospective suppliers who will have access to Cirque's information, information systems, or facilities, or who will process, store, or transmit Cirque's information on its behalf. This procedure ensures that suppliers meet Cirque's information security requirements and helps manage supply chain risks, in accordance with IS-CIRQ-P-013-G: Supplier Relationships Policy and ISO/IEC 27001:2022 Annex A.15.1.

****2. Scope****

2. Scope

This procedure applies to all Cirque departments and personnel involved in engaging with, or managing, suppliers that meet the criteria defined in the IS-CIRQ-P-013-G: Supplier Relationships Policy. This includes all types of suppliers, from cloud service providers to IT service providers and software vendors.

****3. Responsibilities****

3. Responsibilities

- ****IT Manager:**** Overall owner of this procedure. Leads and oversees supplier security reviews, assesses security risks, and approves supplier security postures.
- ****Requesting Department/Service Owner:**** Initiates the supplier engagement process and provides details regarding the data/systems the supplier will access or handle.
- ****Legal Counsel:**** Reviews contractual terms and conditions related to information security.
- ****Procurement Department:**** Facilitates communication with suppliers and ensures security requirements are included in contracts.

****4. Procedure****

4. Procedure

****4.1. Initial Supplier Risk Classification****

a). **Trigger:** This procedure is triggered when a new supplier is considered, or when there is a significant change in the services provided by an existing supplier that impacts information security (e.g., increased data access, new data types, critical system access).

b). **Information Gathering:** The Requesting Department/Service Owner, in consultation with the IT Manager, will gather initial information about the supplier and the proposed services, including:

** Type of service/product provided.

** What \`Cirque\` information (data classification, e.g., Confidential,

Internal Use) the supplier will access, process, or store.

* Which \`Cirquel` systems or facilities the supplier will access.

* Criticality of the service to \`Cirquel`s operations.

c). **Risk Classification:** Based on the gathered information, the IT Manager will classify the supplier`s security risk as:

* **High Risk:** Access to Confidential data (e.g., intellectual property like ASIC designs, customer PII), critical systems (e.g., core financial systems, production servers), or direct management of \`Cirquel`s IT infrastructure.

* **Medium Risk:** Access to Internal Use data, non-critical systems, or providing services that are important but not core to \`Cirquel`s immediate operations.

* **Low Risk:** No access to \`Cirquel`s information or systems, or only to Public information; typically involves generic, non-IT related services.

****4.2. Security Review Activities (Based on Risk Classification)****

a). **High-Risk Suppliers:**

* **Security Questionnaire:** The supplier must complete a detailed security questionnaire (e.g., based on ISO 27001, CSA STAR, or industry-specific frameworks).

* **Documentation Review:** \`Cirquel` will request and review relevant security documentation (e.g., ISO 27001 certificate, SOC 2 Type 2 report, penetration test reports, security policies, incident response plans).

* **Virtual/On-site Audit (Optional, based on need):** If concerns remain or for extremely critical suppliers, a virtual or on-site security audit may be conducted by \`Cirque\`'s IT/Security personnel.

* **Security Architecture Review:** For suppliers providing critical IT services or cloud infrastructure, \`Cirque\`'s IT Manager will review their security architecture and controls.

* **Legal Review:** Comprehensive review of contract security clauses by Legal Counsel.

b\.**Medium-Risk Suppliers:**

* **Abbreviated Security Questionnaire:** The supplier must complete a concise security questionnaire focusing on key control areas.

* **Documentation Review:** Review of basic security certifications or publicly available security statements.

* **Contractual Clauses:** Ensure inclusion of standard information security clauses in the contract.

c\.**Low-Risk Suppliers:**

* **Minimal Review:** Basic due diligence may suffice, primarily focused on ensuring no unforeseen access to \`Cirque\`'s sensitive information occurs. Standard contractual terms (if any) apply.

****4.3. Risk Assessment and Decision****

a\.**Vulnerability Identification:** The IT Manager will analyze the information gathered during the review to identify any security vulnerabilities or gaps in the supplier's controls.

b\.**Risk Scoring:** Identified vulnerabilities and risks will be

assessed and scored (referencing \IS-CIRQ-F-001-G: Risk Assessment Register\).

c. **Remediation Plan:** If significant risks or control gaps are identified, a remediation plan with timelines must be agreed upon with the supplier before engagement.

d. **Approval:** The IT Manager will provide a formal security approval or rejection of the supplier based on the comprehensive review and risk assessment. For high-risk suppliers, executive committee approval may be required.

****4.4. Contractual Inclusion of Security Requirements****

a. Following security approval, the Procurement Department, with input from the IT Manager and Legal Counsel, will ensure all agreed-upon information security requirements and commitments are accurately reflected and legally binding within the supplier contract.

****4.5. Ongoing Monitoring and Re-evaluation****

a. **Regular Monitoring:** The IT Manager and Requesting Department will monitor the supplier's ongoing compliance with security requirements as per \IS-CIRQ-P-013-G: Supplier Relationships Policy\ . This may include periodic review of security reports or performance.

b. **Re-evaluation Triggers:** A new security review (following this procedure) shall be triggered if:

* The supplier's service changes significantly, increasing their access or data handling responsibilities.

* A security incident occurs involving the supplier.

* The supplier's security posture is publicly questioned or known to

have been compromised.

* At a minimum, for high and medium-risk suppliers, a re-evaluation should occur at least every two years, or as determined by contractual terms.

****5. Documentation****

5. Documentation

All supplier security review activities, including risk classifications, questionnaires, documentation reviews, remediation plans, and approval decisions, shall be documented and retained for audit purposes.

****6. Review and Update****

6. Review and Update

This procedure will be reviewed at least annually, or sooner if there are significant changes to Cirque's supplier engagement processes, risk appetite, or relevant legal/regulatory requirements.

****7. Related Documents****

7. Related Documents

- IS-CIRQ-P-013-G: Supplier Relationships Policy
- IS-CIRQ-F-001-G: Risk Assessment Register
- IS-CIRQ-P-007-G: Asset Management Policy
- IS-CIRQ-PR-007-G: Asset Classification and Handling Procedure
- IS-CIRQ-P-001-G: Information Security Policy